

BLACK-BOX PENETRATION TEST

Ethical Hacking & Cybersecurity | Batch B082

Password cracker Name (Cybersecurity Professional)	Mosotho Thatho
Program/Batch	B082-Networkwalks
Date	08 September 2026
Modules completed	M1: Initial Access M2: Data Extraction M3: Getting access DB
Clients/Target	Mediroza General Hospital

1. Executive Summary

This report documents the results of an authorised black-box penetration-testing exercise performed against the Mediroza General Hospital training environment as part of the Networkwalks Ethical Hacking & Cybersecurity programme. The assessment followed the milestone structure supplied for the exercise: initial access to the patient portal, recovery of three protected laboratory reports, analysis of the recovered files, and investigation of the deeper data exposure identified through that analysis.

The assessment demonstrated that weaknesses at different stages could be chained together. The web application disclosed information that should not have been returned to an end user during authentication testing. After access to the restricted patient area was obtained, three encrypted laboratory reports were retrieved. The report encryption was then successfully recovered during the assigned password-recovery exercise.

The most significant finding occurred during analysis of the decrypted PDFs. File metadata contained an internal operational comment that revealed the existence and location of a legacy database backup. The backup was subsequently accessible from the web environment and contained confidential staff and shareholder information. This transformed what initially appeared to be a document access issue into a broader confidentiality exposure affecting organisational and personnel data.

Key outcomes:

- A restricted patient portal area was accessed through a weakness in the application's handling of authentication input.
- Three encrypted laboratory reports were retrieved, and their contents were successfully recovered using the assigned password recovery methods.
- PDF metadata was examined using ExifTool, revealing an internal comment that provided a lead to a legacy database backup.
- The exposed backup contained staff and shareholder/equity tables, including salary and ownership related information.
- Sensitive records were not reproduced in this report; only the categories and security impact are documented.

2. Scope and Methodology

The exercise was conducted as a full black-box penetration test of the authorised Mediroza General Hospital web application in a controlled Networkwalks training environment. The project brief specified a five day assessment and limited testing to the target domain. Social engineering, denial of service activity and testing outside the agreed scope were excluded.

2.1 Assessment Approach

1. Reconnaissance and identification of exposed web application entry points.
2. Review of authentication behaviour and application responses to controlled input.
3. Verification of access to the restricted patient report area.
4. Retrieval of the three assigned encrypted PDF reports.
5. Password recovery testing using the provided training tools and appropriate wordlists.
6. Static examination of the decrypted files, including metadata and document properties.
7. Investigation of the internal lead disclosed by PDF metadata.
8. Verification of the exposed database backup and identification of the affected data categories.
9. Documentation of evidence and development of remediation recommendations.

2.2 Tools and Resources Used:

Tools/Resources	purpose in the assessment
Windows PC/Host	Used as the primary workstation for practical exercise.
Kali Linux VM	Used for security testing, file handling and metadata analysis.
Networkwalks Hash Calculator	Generated hash representations for the protected PDF files during password-recovery testing.
Networkwalks Password Cracker	Attempted password recovery using available wordlists.
Custom Wordlist	Used when the built-in Networkwalks wordlist did not find a matching password.
Exiftool	Inspected decrypted PDF metadata and document properties

2.3 Limitations

- Testing was restricted to the authorised training target and the activities defined by the Networkwalks exercise.

- No denial of service, social engineering or out of scope infrastructure testing was performed.
- The report deliberately omits passwords, hashes, exact server locations, patient medical information, employee personal identifiers and other sensitive values.
- The assessment represents a time-bounded training exercise and should not be interpreted as a complete security audit of every hospital system.

3. Findings and Proof of Exploitation

The following findings are presented in the order in which the assessment progressed. Screenshots are included as supporting evidence but have been redacted to prevent the report itself from becoming a source of sensitive operational or personal information.

3.1 Authentication/Input Handling Weakness

During testing of the patient-portal login, the application returned a detailed database related error in response to crafted authentication input. The response disclosed implementation details that should normally remain server side. Further controlled testing demonstrated that the authentication control could be bypassed within the authorised lab environment, allowing access to the restricted patient-report area.

The important security issue is not the particular test string used during the exercise; it is that user controlled authentication input reached the database layer without sufficient protection and that the resulting database error was exposed to the client.

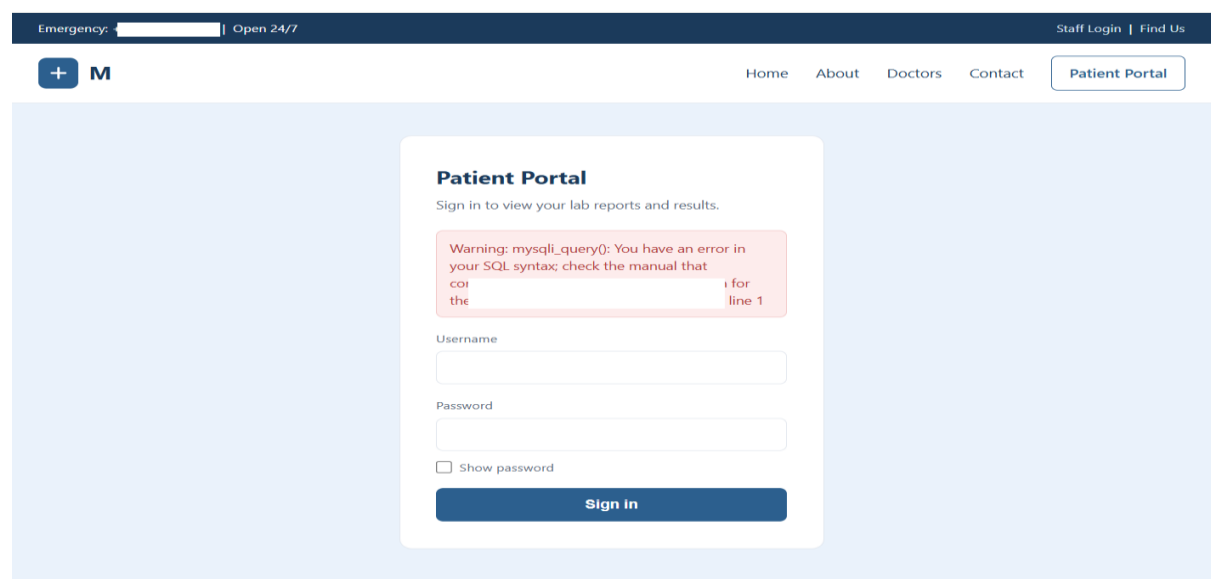


Figure 1. Redacted evidence of the authentication response. The exact test input and target address have been removed

Impact

- Unauthorised access to a restricted application area was possible.
- Database implementation details were disclosed through an error response.
- The weakness provided the initial foothold used to retrieve the assigned reports.
- In a real environment, similar weaknesses could allow access to other accounts or protected records depending on application privileges.

3.2 Protected Documents Accessible After Portal Compromise and Recoverable PDF Passwords

After obtaining access to the restricted patient report area, three encrypted laboratory reports were available for download. The exercise required recovery of the protection applied to each file. Using the assigned Networkwalks password recovery tools, the passwords were recovered and each report was successfully opened for verification.

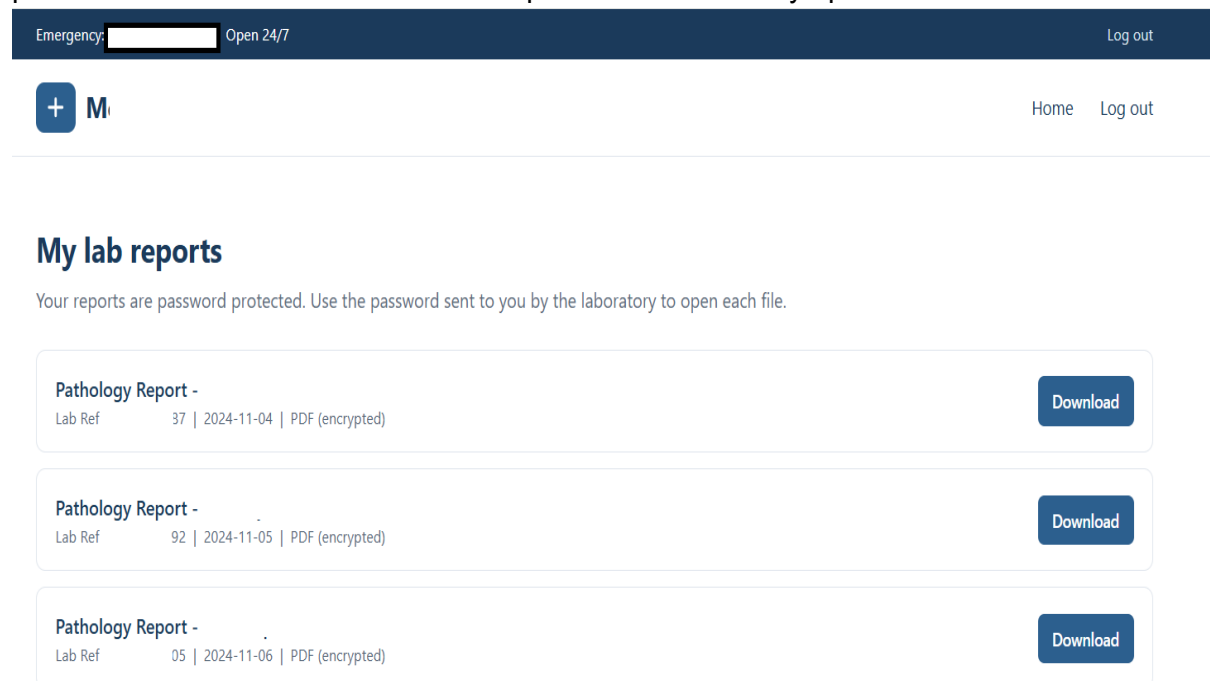


Figure 2. Redacted patient portal evidence showing the presence of three protected laboratory reports.

The next step is to download the PDF files and recover their password using networkwalks tools. The passwords for the first two PDF files was discovered using build-in wordlist, but the third PDF file required the use of custom wordlist. The following screenshots shows the inside of each PDF file.

+

Johannesburg, South Africa
Tel: medirozahospital.com

PATHOLOGY LABORATORY REPORT

CONFIDENTIAL

Patient Name:

Patient ID:

Date of Birth:

Gender:

06-12

Male

Report Date:

Referring Dr:

Specimen:

Lab Ref No:

2024-11-04

Whole blood (EDTA)

TEST	RESULT	UNIT	REFERENCE RANGE	FLAG
Haemoglobin	13.9	g/dL	13.0 - 17.0	Normal
White Cell Count	11.8	x10 ⁹ /L	4.0 - 11.0	HIGH
Platelet Count	245	x10 ⁹ /L	150 - 400	Normal
Fasting Glucose	5.4	mmol/L	3.9 - 5.5	Normal
Creatinine	88	umol/L	64 - 104	Normal

Figure 3. Redacted evidence from the first PDF recovered laboratory report.

+

South Africa
Tel: medirozahospital.com

PATHOLOGY LABORATORY REPORT

CONFIDENTIAL

Patient Name:

Patient ID:

Date of Birth:

Gender:

-02-28

Female

Report Date:

Referring Dr:

Specimen:

Lab Ref No:

2024-11-05

Serum

192

TEST	RESULT	UNIT	REFERENCE RANGE	FLAG
Total Cholesterol	6.4	mmol/L	< 5.0	HIGH
LDL Cholesterol	4.1	mmol/L	< 3.0	HIGH
HDL Cholesterol	1.2	mmol/L	> 1.0	Normal
Triglycerides	1.8	mmol/L	< 1.7	HIGH
Fasting Glucose	4.9	mmol/L	3.9 - 5.5	Normal

Figure 4. Redacted evidence from the second PDF recovered laboratory report

+

Mediroza
General Hospital

South Africa
Tel: medirozahospital.com

PATHOLOGY LABORATORY REPORT

CONFIDENTIAL

Patient Name:

Patient ID:

Date of Birth:

Gender:

-09-03

Female

Report Date:

Referring Dr:

Specimen:

Lab Ref No:

2024-11-06

Serum

105

TEST	RESULT	UNIT	REFERENCE RANGE	FLAG
Haemoglobin	11.4	g/dL	12.0 - 15.5	LOW
Ferritin	9	ug/L	15 - 150	LOW
TSH	3.1	mIU/L	0.4 - 4.0	Normal
Vitamin D	42	nmol/L	50 - 125	LOW
Fasting Glucose	5.1	mmol/L	3.9 - 5.5	Normal

Figure 5. Redacted evidence from the third PDF recovered laboratory report.

The screenshots confirm successful retrieval and opening of the assigned documents without publishing the patients' identifying or medical information.

Impact

- Confidential laboratory reports could be retrieved following compromise of the patient portal.
- File-level password protection did not provide sufficient protection against the recovery methods used in the exercise.
- Exposure could have privacy and regulatory consequences in a real healthcare environment because medical reports are highly sensitive records.

3.3 Sensitive Information Disclosure Through PDF Metadata

The decrypted PDFs were examined using ExifTool rather than relying only on the visible report content. Two reports contained ordinary document generation metadata, including the reporting application. The third report contained an additional internal comment associated with document creation. The comment disclosed that a database backup had been moved to a legacy location during a site migration.

```
Producer      : Mediroza Lab Reporting Module
Subject       : Lipid Profile
Title         : Pathology Report - [redacted]
Page Count    : 1

(kali@kali)~[~/Downloads]
$ exiftool patient_report_3_decrypted.pdf
ExifTool Version Number : 11.55
File Name               : patient_report_3_decrypted.pdf
Directory               : .
File Size               : 2.9 kB
File Modification Date/Time : 2026:09:08 04:52:27-04:00
File Access Date/Time   : 2026:09:08 04:52:27-04:00
File Inode Change Date/Time : 2026:09:08 04:52:27-04:00
File Permissions        : -rw-rw-r--
File Type              : PDF
File Type Extension     : pdf
MIME Type              : application/pdf
PDF Version             : 1.4
Linearized             : No
Author                : [redacted]
Comments              : DB backup moved to /old before site migration, do not delete
Creator              : Mediroza CMS 1.4.2
Keywords            : pathology, patient report
Producer            : Mediroza Lab Reporting Module
Subject             : Full Blood Count
Title               : Pathology Report - [redacted]
Page Count           : 1

(kali@kali)~[~/Downloads]
$
```

Figure 6. Redacted ExifTool evidence. The screenshot preserves the metadata analysis context while removing the internal location and other operational details.

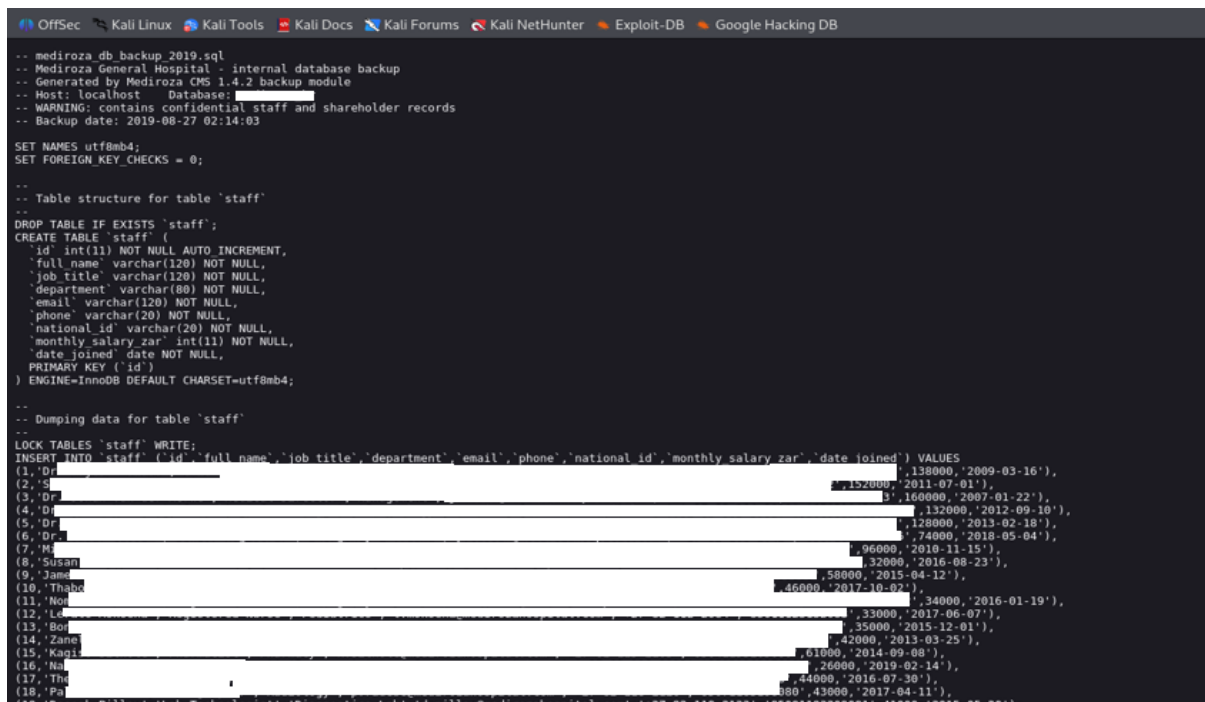
This finding was significant because the metadata supplied an otherwise non-obvious lead to a resource that was not intended to be exposed to normal users.

Impact

- Internal operational information was embedded in a document delivered to an end user.
- The metadata provided a direct lead toward a legacy server resource.
- Information leakage through document metadata can make subsequent enumeration easier for an attacker.

3.4 Web Accessible Database Backup Containing Confidential Organisational Data

Following the metadata lead, the assessment located a legacy database backup exposed through the web environment. The backup itself identified that it contained confidential staff and shareholder records. Review of the backup showed separate staff and shareholder/equity data structures. The staff information included a salary field, while the shareholder information included ownership percentages, share counts and share classes.



```
-- mediroza_db_backup_2019.sql
-- Mediroza General Hospital - internal database backup
-- Generated by Mediroza OMS 1.4.2 backup module
-- Host: localhost Database: [REDACTED]
-- WARNING: contains confidential staff and shareholder records
-- Backup date: 2019-08-27 02:14:03

SET NAMES utf8mb4;
SET FOREIGN_KEY_CHECKS = 0;

--
-- Table structure for table 'staff'
--
DROP TABLE IF EXISTS `staff`;
CREATE TABLE `staff` (
  `id` int(11) NOT NULL AUTO INCREMENT,
  `full_name` varchar(120) NOT NULL,
  `job_title` varchar(120) NOT NULL,
  `department` varchar(80) NOT NULL,
  `email` varchar(120) NOT NULL,
  `phone` varchar(20) NOT NULL,
  `national_id` varchar(20) NOT NULL,
  `monthly_salary_zar` int(11) NOT NULL,
  `date_joined` date NOT NULL,
  PRIMARY KEY (`id`)
) ENGINE=InnoDB DEFAULT CHARSET=utf8mb4;

--
-- Dumping data for table 'staff'
--
LOCK TABLES `staff` WRITE;
INSERT INTO `staff` (`id`,`full_name`,`job_title`,`department`,`email`,`phone`,`national_id`,`monthly_salary_zar`,`date_joined`) VALUES
(1,'Dr [REDACTED]',[REDACTED],[REDACTED],[REDACTED],[REDACTED],[REDACTED],138000,'2009-03-16'),
(2,'S [REDACTED]',[REDACTED],[REDACTED],[REDACTED],[REDACTED],[REDACTED],152000,'2011-07-01'),
(3,'Dr [REDACTED]',[REDACTED],[REDACTED],[REDACTED],[REDACTED],[REDACTED],160000,'2007-01-22'),
(4,'Dr [REDACTED]',[REDACTED],[REDACTED],[REDACTED],[REDACTED],[REDACTED],132000,'2012-09-10'),
(5,'Dr [REDACTED]',[REDACTED],[REDACTED],[REDACTED],[REDACTED],[REDACTED],128000,'2013-02-18'),
(6,'Dr [REDACTED]',[REDACTED],[REDACTED],[REDACTED],[REDACTED],[REDACTED],74000,'2018-05-04'),
(7,'M [REDACTED]',[REDACTED],[REDACTED],[REDACTED],[REDACTED],[REDACTED],96000,'2019-11-15'),
(8,'Susan [REDACTED]',[REDACTED],[REDACTED],[REDACTED],[REDACTED],[REDACTED],32000,'2016-08-23'),
(9,'James [REDACTED]',[REDACTED],[REDACTED],[REDACTED],[REDACTED],[REDACTED],58000,'2015-04-12'),
(10,'Thabaz [REDACTED]',[REDACTED],[REDACTED],[REDACTED],[REDACTED],[REDACTED],46000,'2017-10-02'),
(11,'Non [REDACTED]',[REDACTED],[REDACTED],[REDACTED],[REDACTED],[REDACTED],34000,'2016-01-19'),
(12,'L [REDACTED]',[REDACTED],[REDACTED],[REDACTED],[REDACTED],[REDACTED],33000,'2017-06-07'),
(13,'Bo [REDACTED]',[REDACTED],[REDACTED],[REDACTED],[REDACTED],[REDACTED],35000,'2015-12-01'),
(14,'Zane [REDACTED]',[REDACTED],[REDACTED],[REDACTED],[REDACTED],[REDACTED],42000,'2013-03-25'),
(15,'Kagi [REDACTED]',[REDACTED],[REDACTED],[REDACTED],[REDACTED],[REDACTED],61000,'2014-09-08'),
(16,'Na [REDACTED]',[REDACTED],[REDACTED],[REDACTED],[REDACTED],[REDACTED],26000,'2019-02-14'),
(17,'Th [REDACTED]',[REDACTED],[REDACTED],[REDACTED],[REDACTED],[REDACTED],44000,'2016-07-30'),
(18,'Pa [REDACTED]',[REDACTED],[REDACTED],[REDACTED],[REDACTED],[REDACTED],43000,'2017-04-11'),
(19,' [REDACTED]',[REDACTED],[REDACTED],[REDACTED],[REDACTED],[REDACTED],180,'2017-04-11'),
(20,' [REDACTED]',[REDACTED],[REDACTED],[REDACTED],[REDACTED],[REDACTED],11000,'2016-05-20');
```

Figure 7. Redacted database-backup evidence. The backup location, filename and individual record values have been removed; the database/table structure is retained to demonstrate the nature of the exposure.

The assessment therefore confirmed the two M3 objectives: staff salary information and hospital shareholder/equity information were present in the exposed backup. The underlying personal records are intentionally not reproduced here.

Impact

- Confidential employee compensation information was exposed.
- Hospital ownership and equity information was exposed.
- The backup contained additional personnel data beyond the information required for the exercise.
- Because the file was exposed through the web environment, an attacker would not necessarily need direct database-server access to obtain the information.
- The finding represents a major confidentiality failure and substantially increases the impact of the earlier application weaknesses.

4. Risk Rating

Ratings below reflect the demonstrated impact in the authorised training environment and the potential confidentiality consequences if equivalent weaknesses existed in a production healthcare system.

Finding	Rating	Justification
Authentication/input handling weakness	HIGH 	Enabled access to a restricted area and disclosed database implementation details through error handling.
Recoverable protection on patient PDFs	HIGH 	Allowed confidential laboratory documents to be opened after retrieval; healthcare data carries significant privacy impact.
Sensitive PDF metadata disclosure	HIGH 	Internal operational information provided a useful lead toward a protected backend resource.
Web-accessible database backup	CRITICAL 	Exposed confidential staff and shareholder information and substantially amplified the impact of the preceding weaknesses.

Overall Assessment

CRITICAL. The highest risk issue is the exposed database backup. The findings also demonstrate that application weaknesses and information leakage can combine to create a substantially larger compromise than any single issue considered in isolation.

5. Recommendations and Remediation

Remediation should prioritise removal of the exposed backup and then address the weaknesses that enabled the attack path. The recommendations below are ordered by urgency.

5.1 Immediate Actions: Critical

1. Remove all database backups, archives and migration remnants from web accessible directories.
2. Store backups outside the web server document root and restrict them through strong access controls.
3. Search the web server and deployment repositories for other exposed backup, archive, temporary and migration files.

4. Review access logs for requests to legacy resources and determine whether the exposed backup was accessed outside the authorised test.
5. If the backup contained credentials, keys or other secrets, rotate them immediately and invalidate the affected credentials.

5.2 Application Security: High Priority

- Use parameterised queries/prepared statements for all database operations involving user input.
- Implement server-side validation and strict input handling at authentication boundaries.
- Return generic authentication errors to users and log detailed database errors only on the server.
- Ensure database accounts used by the web application have only the minimum permissions required.
- Perform security testing of all authentication and authorisation paths before deployment.

5.3 Document and Metadata Security

- Remove internal comments, author information, file paths and other operational metadata from documents before they are delivered to users.
- Configure the document-generation system to minimise unnecessary metadata by default.
- Add an automated document sanitisation step for reports generated by the CMS.
- Review existing documents generated by the reporting platform for unintended metadata disclosure.

5.4 Backup and Deployment Controls

- Define a formal backup-retention and secure-deletion process for site migrations.
- Prevent backup extensions and temporary files from being served by the web server.
- Disable directory listing where it is not explicitly required.
- Separate production application content from backup storage.
- Include a deployment checklist item that verifies old directories and migration artifacts are removed after a release.

5.5 Patient Data and File Protection

- Use strong, unique document-protection mechanisms where file-level encryption is required.
- Avoid predictable or easily guessable document passwords.
- Consider authenticated access controls in addition to file level protection.
- Monitor and rate-limit repeated document download and password-recovery attempts where appropriate.
- Apply least privilege so users can access only the reports that belong to their authorised account.

6. Conclusion

The Mediroza General Hospital assessment demonstrated the value of approaching a penetration test as a connected investigation rather than a collection of isolated tool exercises. The initial application weakness provided access to the patient portal; the protected documents were then recovered as required by the exercise; and careful examination of the recovered files revealed information that was not visible in the normal document content.

The most important lesson from the assessment was that security-sensitive information can leak through unexpected places. In this case, document metadata provided the lead that connected the patient-report stage to a legacy database backup. The exposed backup then revealed confidential staff and shareholder information, making the overall exposure substantially more serious.

The recommended remediation is therefore not limited to patching one vulnerability. The organisation should address secure coding, error handling, document sanitisation, backup management, deployment hygiene, access control and monitoring as a combined security programme.

7. Professional Reflection and Lessons Learned

- A successful penetration test requires following evidence from one finding to the next instead of stopping after the first successful access.
- Metadata can contain useful information that is invisible when a document is viewed normally.
- A vulnerability's impact should be assessed in the context of what it enables an attacker to reach next.
- Security tools are most effective when their output is interpreted carefully and verified against the target behaviour.
- Troubleshooting is part of practical penetration testing; when an initial approach does not work, the tester should review assumptions and use an authorised alternative.
- Evidence should be collected in a way that proves the finding without unnecessarily publishing sensitive information.